

T9 - Seguridad

Seguridad de la información

Tipos de seguridad

Área amplia que aborda muchos problemas:

1. Cuestiones **legales y éticas** relacionadas con el **derecho a acceder a cierta información**.

Cierta información puede considerarse privada y no pueden acceder legalmente organizaciones o personas que no están autorizadas.

2. Cuestiones de **política a nivel gubernamental, institucional o corporativo** con respecto a la **información que no debería ponerse a disposición de todos**.

Calificaciones crediticias y registros médicos personales.

3. Necesidad de algunas organizaciones de **identificar múltiples niveles de seguridad y categorizar los datos y los usuarios basándose en estas clasificaciones**.

Alto secreto, secreto, confidencial y no clasificado. Basándose en estas clasificaciones, se deben tomar las políticas de seguridad respectivas.

Seguridad de la información

La gobernanza, privacidad y compliance se nutren a partir de la capacidad de una empresa de mantener segura la información.

Esto implica:

- **Confidencialidad.** La información sólo *la pueden ver quienes estén autorizados* a verla.
- **Integridad.** *No pueden haber modificaciones* de la información por parte *de personas no autorizadas*.
- **Disponibilidad.** La información está *disponible para los que estén autorizados en el momento que la necesiten*.

Las *estrategias y técnicas alrededor de la seguridad* incluyen:

- **Autenticación.** Verificación de identidad
- **Control de acceso.** Verificación de que los actores autorizados accedan a la información correcta.
- **Encriptación.** Oscurecimiento de la información si cae en manos equivocadas.
- **Firewalls o sistemas de detección.** Detección y prevención el acceso a redes y sistemas.

Medidas de control

Garantizan la seguridad de los datos en las bases de datos.

1. Medidas de control de inferencia.

Si tuviéramos una base de datos para estadísticas de población para proporcionar estadísticas basadas en grupos de edad, ingresos, etcétera...

Un *usuario* de esta base de datos puede acceder a la misma, pero *no debería poder acceder a información confidencial* sobre alguna persona en específico. *Tampoco debería poder inferir ciertas cosas a partir de las estadísticas.*

2. Cifrado de datos (Data Encryption).

Sirve para *proteger datos confidenciales* (contraseñas, tarjetas de crédito) que viajan a través de algún tipo de red.

El *usuario no autorizado* que quiera acceder no podrá descifrar el dato confidencial.

El *usuario autorizado* recibirá el algoritmo de decodificación para descifrar el mensaje.

3. Control de acceso.

El *administrador central de la base de datos (DBA)* tiene la *responsabilidad* de la seguridad general de la base de datos y la *autoridad* para gestionar el sistema. Esto es, *otorgar privilegios* a los usuarios que requieran acceso y *clasificar usuarios y datos* según la política de la organización.

El DBA tiene una cuenta especial en la base de datos que se llama **superusuario**. Este título otorga *facultades que no tienen las demás cuentas sin privilegios*, como otorgar y revocar privilegios para cuentas individuales o grupos de cuentas.

Control de acceso

Control de acceso discrecional basado en concesión y revocación de privilegios (DAC)

El método por preferencia para cumplir el control de acceso se basa en el *otorgamiento y revocación de privilegios*. Se incluyen *declaraciones en el lenguaje de consulta* que permitan al DBA (el administrador) y a algunos para hacerlo posible.

Un usuario tiene o no tiene un privilegio en específico. No hay grises.

Control de acceso obligatorio (MAC)

Es una *política de seguridad adicional que clasifica datos y usuarios según clases de seguridad*.

Este método se combina con el mecanismo DAC previo: primero se aplican los privilegios discretivos (tenés un privilegio o no), y además se chequea que el nivel de seguridad del usuario sea compatible con el nivel del dato al que quiere acceder.

Control de acceso basado en roles (RBAC)

Acá los *privilegios* y otros permisos están *asociados con roles organizacionales, no con usuarios individuales*.

Se pueden asignar *varios usuarios a un rol*.

Una empresa puede tener funciones como cuenta de ventas, gerente, agente de compras, etcétera.

Un **rol** *agrupa funciones y niveles de responsabilidad*. Implican una jerarquía donde cada rol hereda las capacidades de sus ancestros.

Un **usuario** es un *miembro de la organización con algún acceso a los datos*.

Un **objeto** es un elemento sobre el cual se puede controlar el acceso.

Tienen jerarquía:

- 1) **Base de datos**. *Conjunto de esquemas* y un único sistema de permisos. Puede haber más de una base en el mismo motor.
- 2) **Esquema**. Separación lógica de objetos dentro de una base de datos. *Conjunto de objetos*.
- 3) **Objetos atómicos**. Tablas, vistas, funciones, índices...

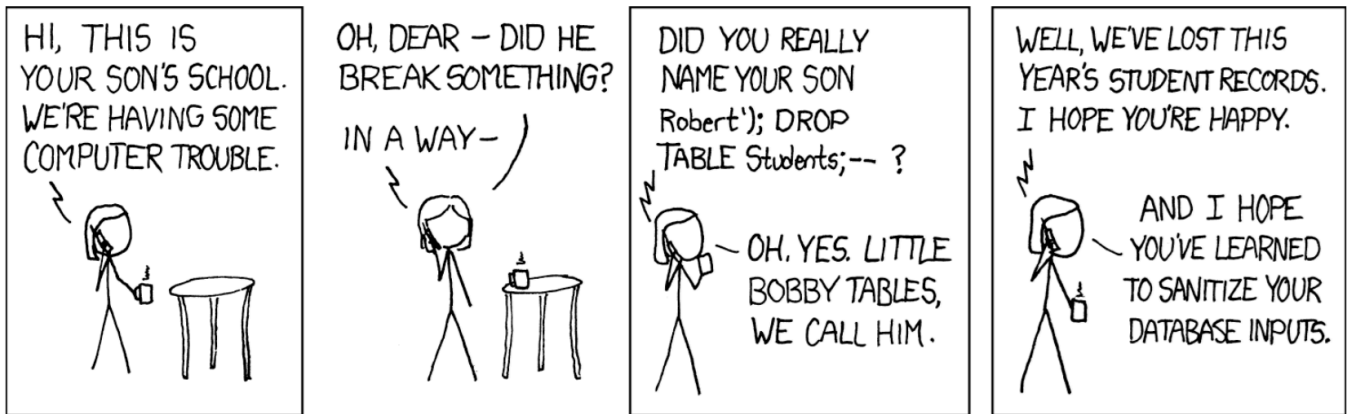
Una **operación** es una acción de las tantas que se pueden tomar sobre los objetos.

Podría agregar todo lo que es implementación de RBAC en PostgreSQL.

Ataques de seguridad

Las bases de datos son un tipo de infraestructura que no están expuestos a redes externas, pero se puede acceder de forma indirecta a través de servicios que sí se exponen. Por eso, pueden ser víctimas de ataques.

SQL Injection



Se aprovechan del hecho de que *algunos servicios y aplicaciones usan input externo como parte de sus consultas a la base de datos.*

Este ataque está orientado a *obtener información no autorizada, alterar información o destruirla* (como en el caso de la tira de arriba).